

WEEK 5 – CYBER SECURITY INTERNSHIP

VAPT TOOLS – PRACTICAL LEARNING

Vulnerability Assessment and Penetration Testing using Nmap, Nikto and Burp Suite

Submitted by: PAILACHUKKA SUSMITHA

Domain: Cyber Security Week: 5

Target Environment: Authorized Local Ubuntu Apache Web Server

Target IP: 192.168.56.101 Attacker: Kali Linux

Tools: [Nmap](#) | [Nikto](#) | [Burp Suite](#) | [VirtualBox Lab](#)

Table of Contents

- 1. Introduction
- 2. Objectives
- 3. Lab Environment
- 4. Target Selection and Connectivity Limitation
- 5. Nmap – Network Scanning
- 6. Nikto – Web Server Scanning
- 7. Burp Suite – HTTP Request Analysis
- 8. VAPT Findings Summary
- 9. Security Impact
- 10. Recommended Mitigations
- 11. Learning Outcomes
- 12. Challenges Faced
- 13. Conclusion
- 14. Tools Used

1. Introduction

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing process used to identify weaknesses, misconfigurations, exposed services, and potential security issues in systems and applications.

The objective of this week's practical activity was to gain hands-on experience with commonly used VAPT tools and understand how security professionals perform basic reconnaissance, service identification, web-server scanning, and HTTP traffic inspection.

The practical focused on three tools:

- Nmap – Network scanning and service/version detection
- Nikto – Web server security assessment
- Burp Suite – HTTP request interception and analysis

All testing described in this report was performed only against an authorized lab environment owned and operated by the student. No public or third-party systems were scanned or tested.

2. Objectives

- Understand the basic concept of VAPT.
- Perform network reconnaissance using Nmap.
- Identify open ports and running services.
- Perform service and version detection.
- Perform aggressive Nmap scanning in an authorized lab.
- Assess the web server using Nikto.
- Identify missing HTTP security headers and information disclosure.
- Understand HTTP requests using Burp Suite.
- Capture and inspect HTTP request headers.

- Document security findings.
- Understand the importance of testing only authorized systems.

PAILACHUKKA SUSMITHA

3. Lab Environment

The practical was performed using a virtual cybersecurity laboratory built in Oracle VirtualBox, with an attacker machine and a target machine connected over an isolated Host-Only network.

Component	Configuration
Attacker Machine	Kali Linux
Target Machine	Ubuntu Linux
Target Web Server	Apache2
Target IP	192.168.56.101
Network	VirtualBox Host-Only Network
Network Range	192.168.56.0/24
Web Protocol	HTTP
Web Port	80/TCP
Testing Tools	Nmap, Nikto, Burp Suite, VirtualBox

The Ubuntu machine hosted the Apache default web page and acted as the authorized target for the VAPT exercises. Connectivity between the attacker and target was verified before any scanning was performed.

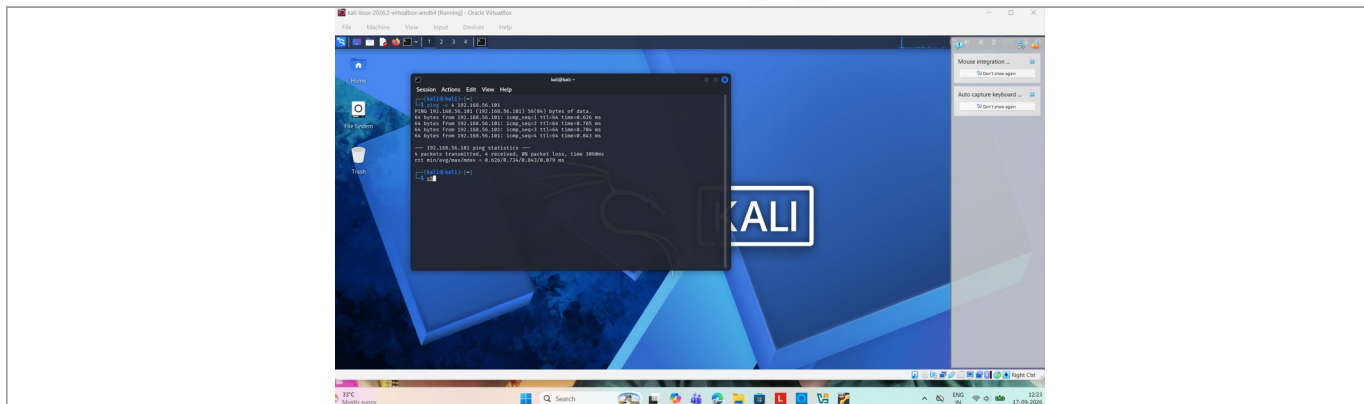


Figure 1: Connectivity verification between the Kali attacker and the authorized Ubuntu target (192.168.56.101).

The ping test returned four successful replies with 0% packet loss, confirming that the Kali attacker machine could reach the Ubuntu target across the Host-Only network before testing began.

4. Target Selection and Connectivity Limitation

The assignment provided the intentionally vulnerable website <http://testphp.vulnweb.com> as the intended target for this practical.

The target was tested for reachability from the lab environment, but the website could not be reached from the available network connection. Network connectivity checks showed that the domain resolved to an IP address, but connections to HTTP/HTTPS timed out or were filtered from the lab network.

Because the assignment permitted a safe alternative and the objective was to perform the VAPT exercises, an authorized local Ubuntu Apache server was selected as the alternative target:

<http://192.168.56.101>

This target was part of the student's own VirtualBox cybersecurity lab and therefore provided a controlled and fully authorized environment for the practical exercises.

IMPORTANT: The assigned public test website (testphp.vulnweb.com) was NOT successfully scanned. All findings reported in this assessment come exclusively from the authorized local Ubuntu target at 192.168.56.101.

5. Nmap – Network Scanning

Nmap is a network discovery and security auditing tool used to identify hosts, open ports, running services, and service versions. The following scans were performed against the authorized Ubuntu target at 192.168.56.101.

5.1 Nmap SYN Scan

```
nmap -sS 192.168.56.101
```

Purpose: The SYN scan was used to identify accessible TCP ports on the target without establishing a full TCP connection in the usual way.

Observation: 80/tcp was identified as an open HTTP service; the remaining 999 scanned TCP ports were reported closed (reset).

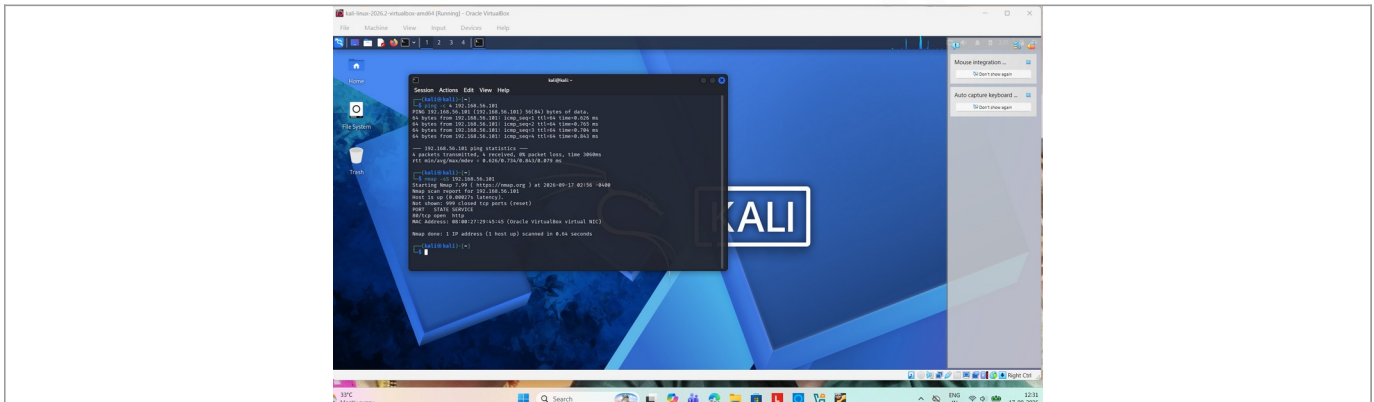


Figure 2: Nmap SYN scan identifying the accessible HTTP service.

5.2 Nmap Service and Version Detection

```
nmap -sV 192.168.56.101
```

Purpose: The -sV option was used to identify the service and version running on the open port.

Result: 80/tcp – HTTP – Apache httpd 2.4.66 ((Ubuntu))

Observation: The target was running an Apache HTTP web server on port 80.

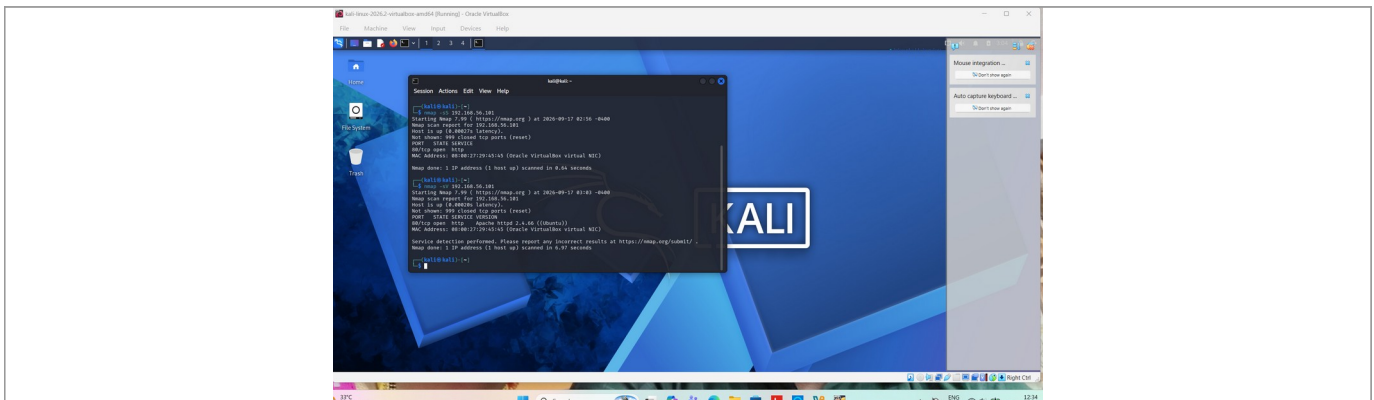


Figure 3: Nmap service/version detection identifying Apache 2.4.66 on port 80.

5.3 Nmap Aggressive Scan

```
nmap -A 192.168.56.101
```

Purpose: The aggressive scan was used to collect additional information such as service detection and basic host information.

- Host was up (0.0011s latency).
- TCP port 80 was open.
- Apache httpd 2.4.66 ((Ubuntu)) was detected.
- HTTP title: Apache2 Ubuntu Default Page: It works
- HTTP server header: Apache/2.4.66 (Ubuntu)
- No exact OS match was found for the host; Nmap returned only a TCP/IP fingerprint.

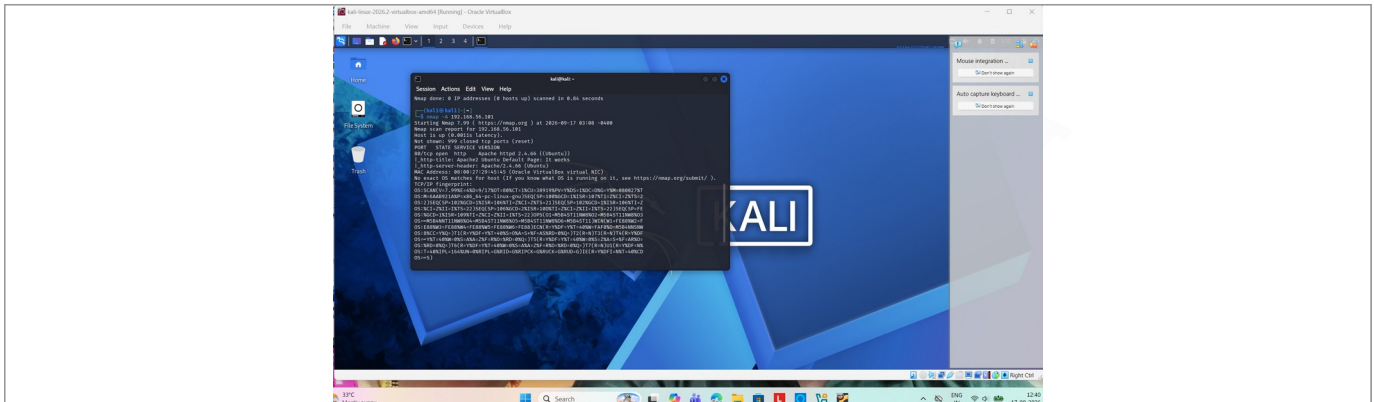


Figure 4: Nmap aggressive scan providing additional information about the target web server.

6. Nikto – Web Server Scanning

Nikto is an open-source web server scanner used to identify potentially insecure configurations, outdated components, dangerous files, and missing security controls. The authorized Ubuntu Apache server was scanned using:

```
nikto -h http://192.168.56.101
```

The scan (Nikto v2.6.0) confirmed the target as 192.168.56.101 on port 80, running Apache/2.4.66 (Ubuntu) on a Linux/Unix platform, and identified several security-related observations.

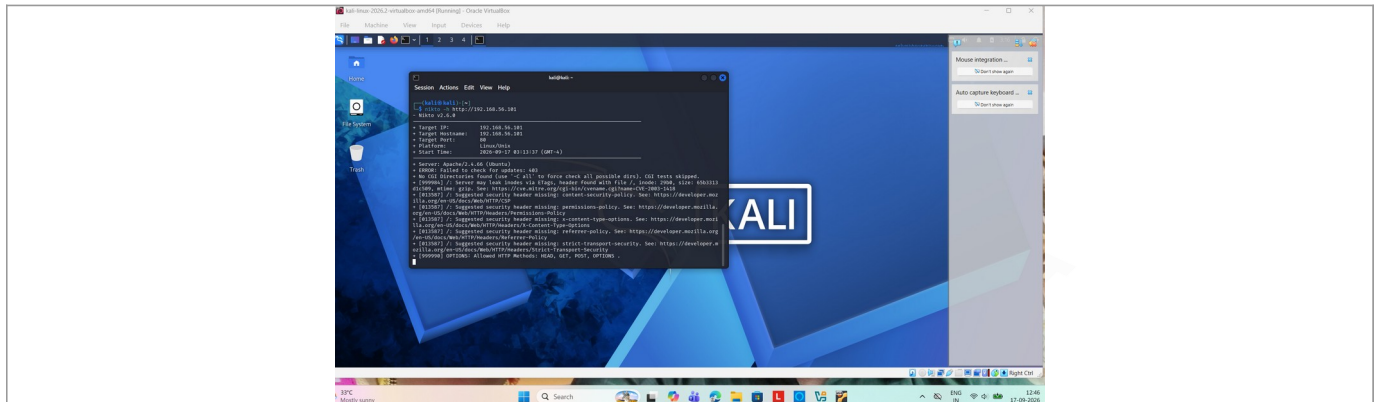


Figure 5: Nikto scan results for the authorized Ubuntu Apache web server.

6.1 Nikto Findings

#	Finding	Explanation
1	Missing Content-Security-Policy header	This header helps control which resources a browser is allowed to load. Its absence may reduce protection against certain browser-based attacks.
2	Missing Permissions-Policy header	This header can restrict access to selected browser features. Its absence means these controls are not explicitly configured.
3	Missing X-Content-Type-Options header	This header helps prevent browsers from MIME-sniffing responses. Its absence represents a missing recommended security control.
4	Missing Referrer-Policy header	This header controls how much referrer information is sent with requests. Its absence means a specific policy is not configured.
5	Missing Strict-Transport-Security header	HSTS instructs browsers to use HTTPS. Since this lab service operated over HTTP, HSTS was not configured.
6	ETag / inode information disclosure	Nikto reported that the server may leak inodes via ETags, potentially exposing filesystem-related metadata.
7	HTTP methods observed	Allowed methods reported: HEAD, GET, POST, OPTIONS. These should be reviewed so only required functionality is exposed.

7. Burp Suite – HTTP Request Analysis

Burp Suite is a web application security testing platform that can intercept and inspect HTTP requests and responses. Burp Suite Community Edition v2026.3.2 was used in this practical.

Proxy configuration: 127.0.0.1:8080

Target: http://192.168.56.101

The Burp Browser was used to access the authorized local Ubuntu Apache server with interception enabled.

7.1 HTTP Request Capture

The first HTTP request captured was:

```
GET / HTTP/1.1
Host: 192.168.56.101
```

Additional request headers observed included Accept-Language, Upgrade-Insecure-Requests, User-Agent, Accept, Accept-Encoding, and Connection. The request demonstrated how a browser communicates with a web server using HTTP.

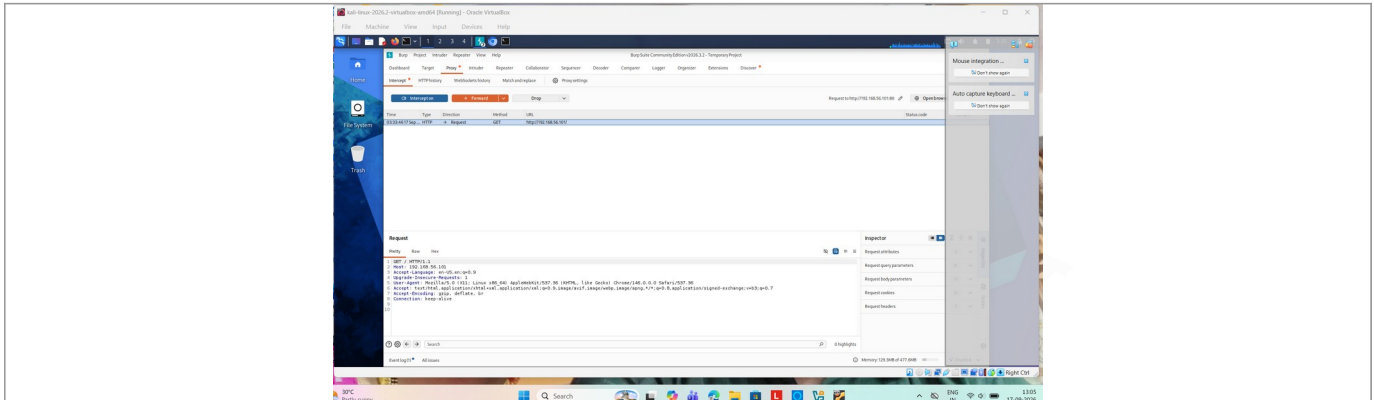


Figure 6: Burp Suite intercepting an HTTP GET request to the authorized Ubuntu web server.

7.2 Second HTTP Request Capture

A second HTTP GET request was intercepted while accessing the local web server. This request included the same GET / HTTP/1.1 and Host: 192.168.56.101 lines, along with additional conditional-request headers — Cache-Control, If-None-Match, and If-Modified-Since — reflecting browser caching behaviour on a repeat visit.

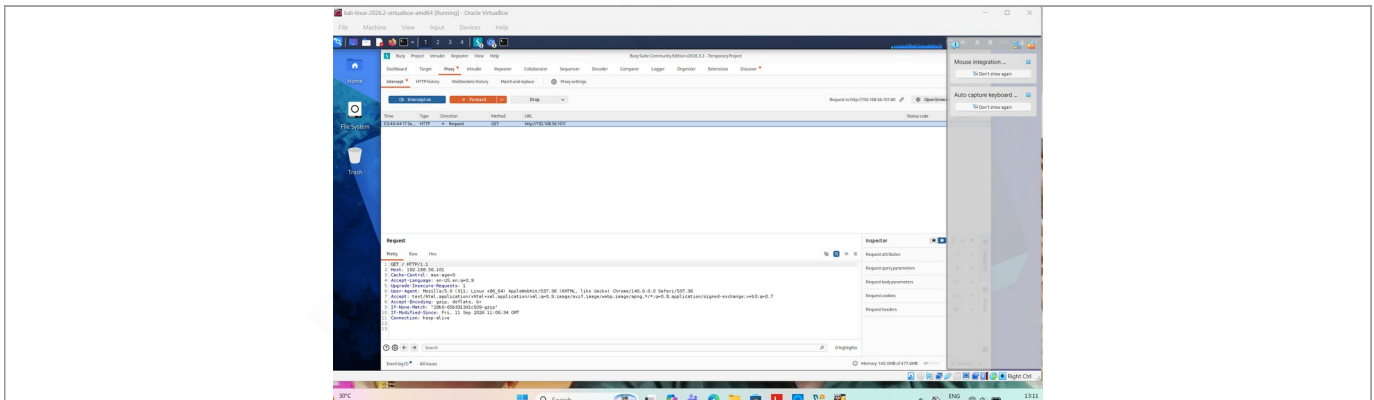


Figure 7: Second HTTP request captured using Burp Suite, showing conditional caching headers.

8. VAPT Findings Summary

The practical produced the following observations across the three tools used:

#	Tool	Finding	Observation
1	Nmap	Open HTTP service	TCP port 80 was open and running Apache HTTP Server.
2	Nikto	Missing Content-Security-Policy	The web server did not return a Content-Security-Policy header.
3	Nikto	Missing Permissions-Policy	The web server did not return a Permissions-Policy

#	Tool	Finding	Observation
			header.
4	Nikto	Missing X-Content-Type-Options	The recommended X-Content-Type-Options header was missing.
5	Nikto	Missing Referrer-Policy	A specific Referrer-Policy header was not configured.
6	Nikto	Missing Strict-Transport-Security	HSTS was not configured because the service was accessed over HTTP.
7	Nikto	ETag / inode information disclosure	ETag information potentially exposed filesystem-related metadata.
8	Burp Suite	HTTP request information	HTTP requests exposed headers such as Host, User-Agent, and Accept.

These are configuration and security-hardening observations identified during an authorized lab exercise. They are not proof of successful exploitation, and an open port is not by itself a confirmed vulnerability.

9. Security Impact

The identified observations demonstrate several areas where the web server configuration could be improved.

Open HTTP service: An HTTP service exposes a web application without transport encryption.

Missing security headers: The absence of recommended security headers reduces the browser-side security controls available to the application.

ETag/inode disclosure: Exposing filesystem-related metadata may provide unnecessary information to an attacker.

HTTP request visibility: Burp Suite demonstrated that HTTP requests contain useful metadata such as the Host and User-Agent headers.

These findings should be treated as configuration and security-hardening observations rather than proof of successful exploitation.

10. Recommended Mitigations

- Enable HTTPS using a valid TLS certificate.
- Configure Strict-Transport-Security after HTTPS is correctly implemented.
- Add Content-Security-Policy according to application requirements.
- Configure Permissions-Policy where appropriate.
- Add X-Content-Type-Options: nosniff.
- Configure an appropriate Referrer-Policy.
- Review ETag configuration if filesystem metadata exposure is unnecessary.
- Review enabled HTTP methods and disable unnecessary methods.
- Keep Apache and operating-system packages updated.
- Perform regular vulnerability assessments.
- Monitor server logs for suspicious activity.
- Use security headers based on the application's actual requirements.

11. Learning Outcomes

Through this practical, the following was learned:

- How Nmap can be used for network reconnaissance.
- How to identify open ports and services.
- How service/version detection works.
- How aggressive Nmap scanning provides additional information.
- How Nikto can identify web-server security issues.
- The importance of HTTP security headers.
- How Burp Suite intercepts HTTP requests.
- How browser requests contain headers and metadata.
- How VAPT findings can be documented.
- The importance of performing security testing only on authorized systems.

12. Challenges Faced

The main challenge was accessing the assignment-provided vulnerable website. The assigned target was unreachable from the available lab network, and the issue was investigated using network connectivity and port checks.

Instead of scanning an unauthorized public website, an authorized Ubuntu Apache server in the student's own VirtualBox lab was used as a controlled alternative.

Another challenge was understanding the Burp Suite interception workflow and ensuring that requests were captured correctly. These challenges helped improve practical troubleshooting and understanding of network and web security tools.

13. Conclusion

This week's practical provided hands-on experience with basic Vulnerability Assessment and Penetration Testing tools. Nmap was used to identify the open HTTP service and determine the Apache version. Nikto was used to assess the web server and identify missing security headers and information disclosure. Burp Suite was used to intercept and inspect HTTP requests.

The practical also demonstrated the importance of maintaining an authorized testing environment and documenting limitations accurately — in this case, clearly recording that the assigned public target was unreachable and that an authorized local alternative was used instead.

Overall, the exercise improved understanding of reconnaissance, web-server assessment, HTTP request analysis, security findings, and basic security hardening.

14. Tools Used

Tool	Version / Detail
Kali Linux	Attacker machine
Ubuntu Linux	Target machine
VirtualBox	Host-Only lab virtualization

Tool	Version / Detail
Nmap	7.99
Nikto	2.6.0
Burp Suite	Community Edition 2026.3.2
Apache	2.4.66 (Ubuntu)

PAILACHUKKA SUSMITHA